Шаблон для поисковых запросов ELK

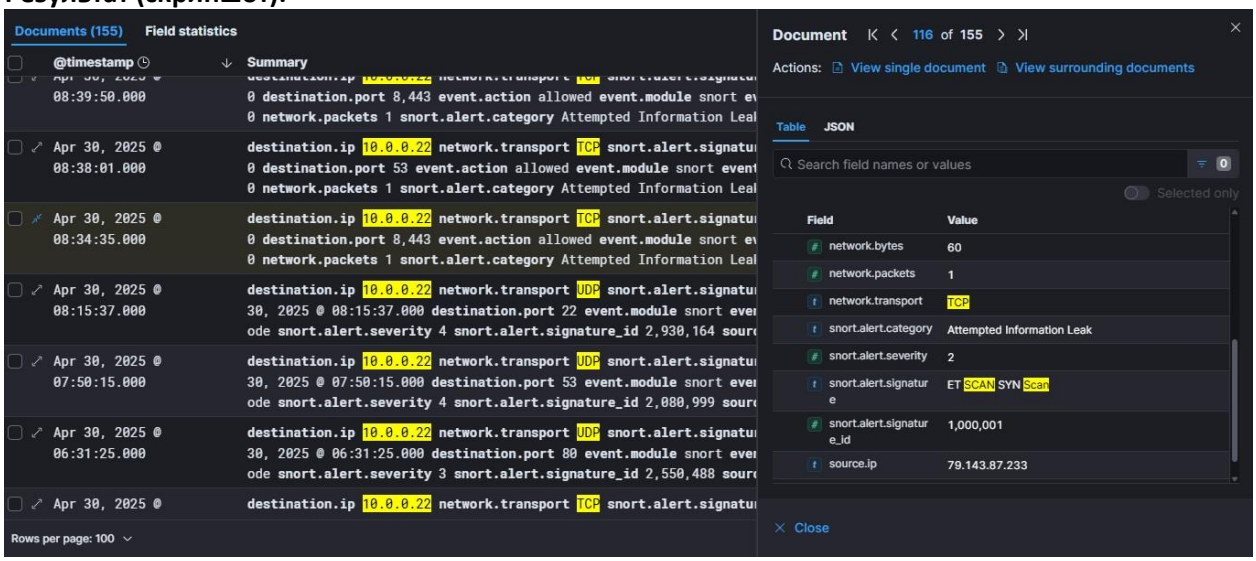
Этап 1

Запрос 1

Что ищем: Сканирование портов в сторону веб-сервера 10.0.0.22

```
Запрос: snort.alert.signature: *SCAN and destination.ip: 10.0.0.22 and
network.transport: (TCP or UDP)
```

Результат (скриншот):

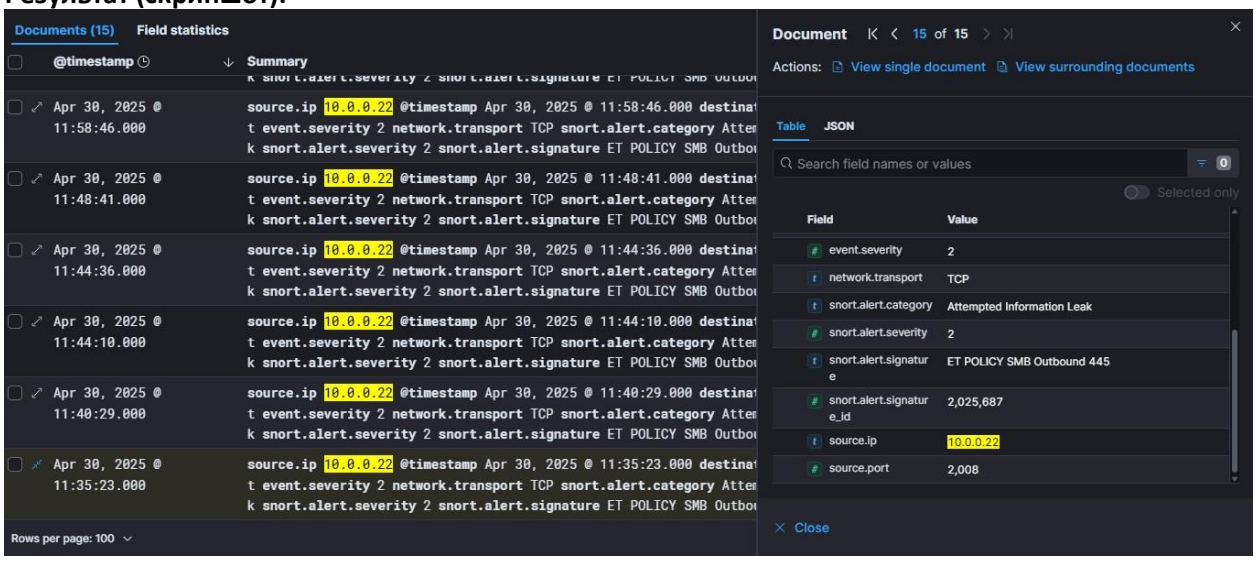


Запрос 2

Что ищем: Все действия подозрительного IP-адреса

```
Запрос: source.ip: 79.143.87.233
```

Результат (скриншот):

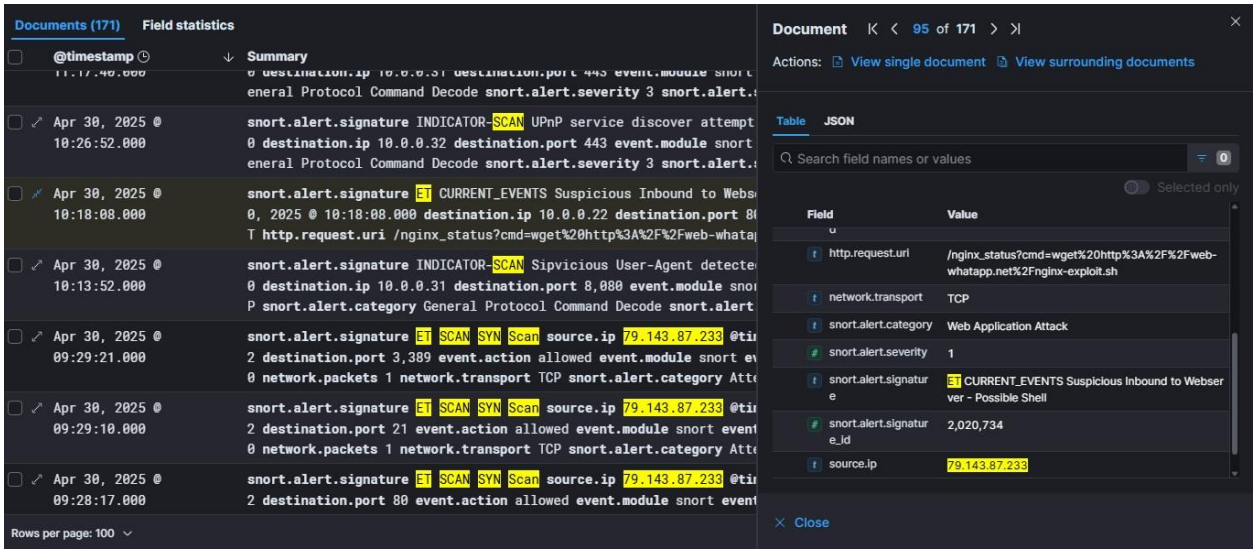


Запрос 3

Что ищем: Смотрим на действия подозрительного ip-адреса и стараемся убрать лишний шум, пытаемся найти SYN-запросы

```
Запрос: source.ip: 79.143.87.233 and snort.alert.signature: ET SCAN SYN Scan
```

Результат (скриншот):



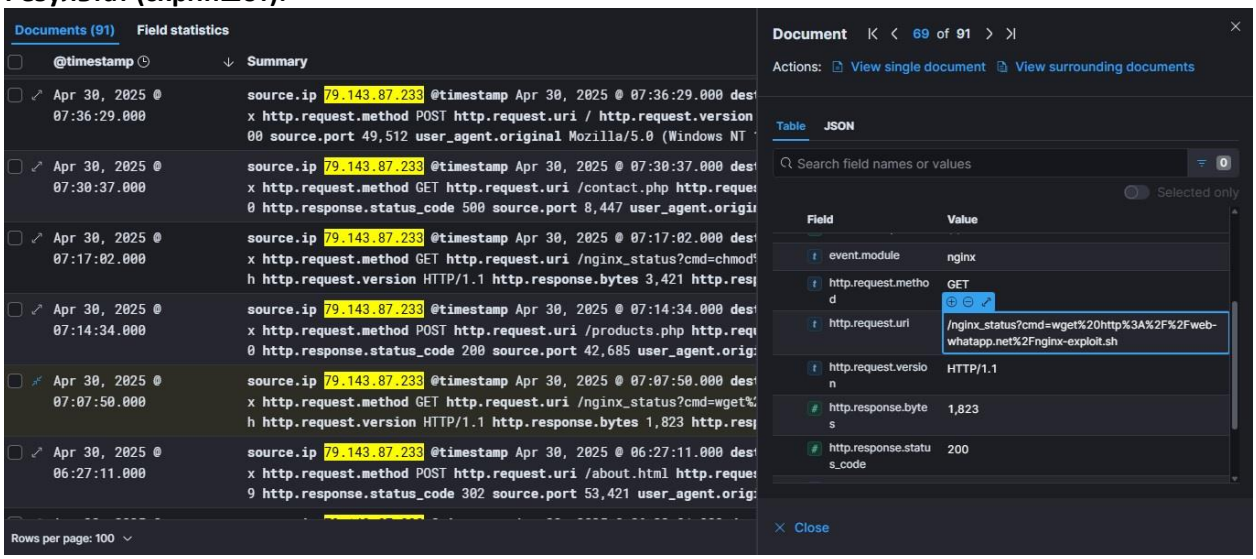
Этап 2

Запрос 1

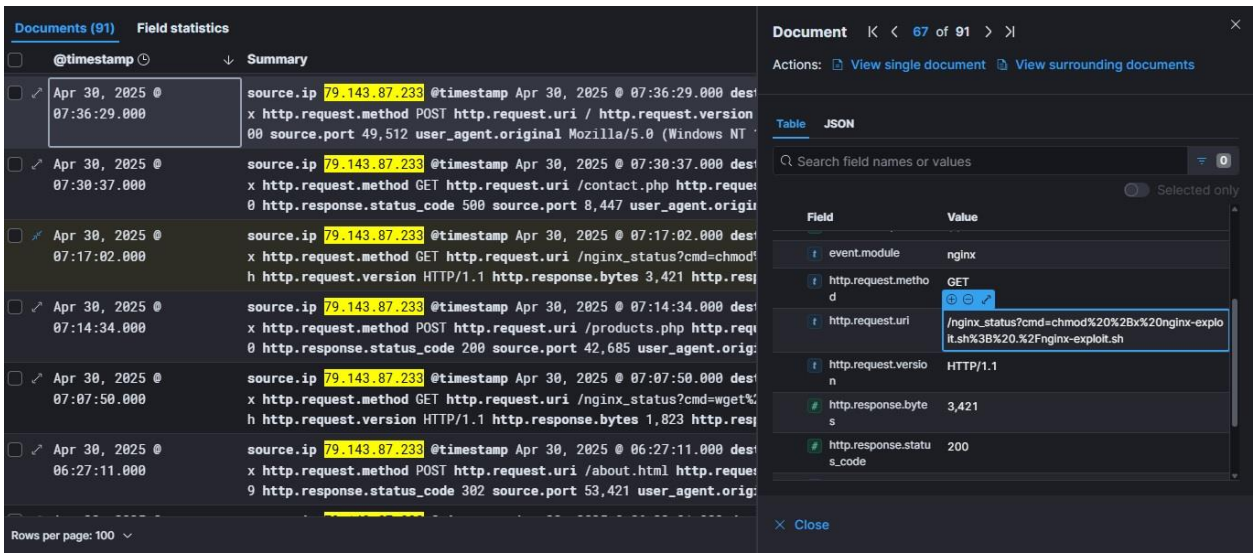
Что ищем: Эксплуатация уязвимости Nginx через параметр cmd

```
Запрос: source.ip: "79.143.87.233" and *cmd*
```

Результат (скриншот):



Далее в следующем логе мы видим, как злоумышленник делает загруженный файл исполняемым. Скриншот:

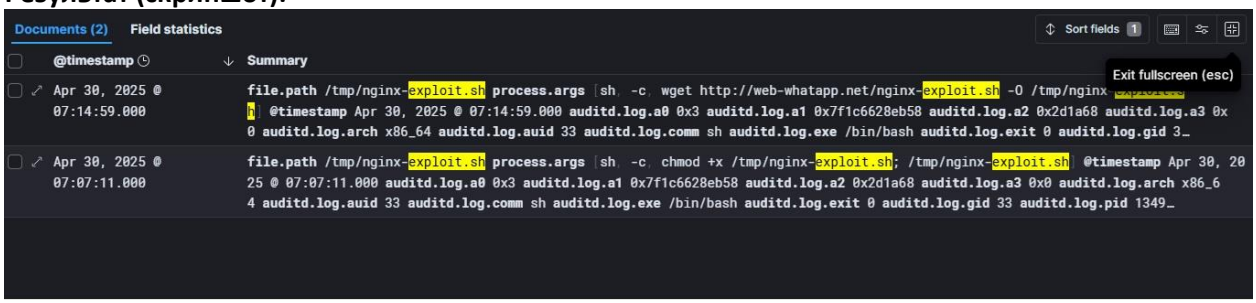


Запрос 2

Что ищем: Мы видели эксплуатацию уязвимости, ищем сам файл в логах auditd

```
Запрос: *exploit.sh*
```

Результат (скриншот):



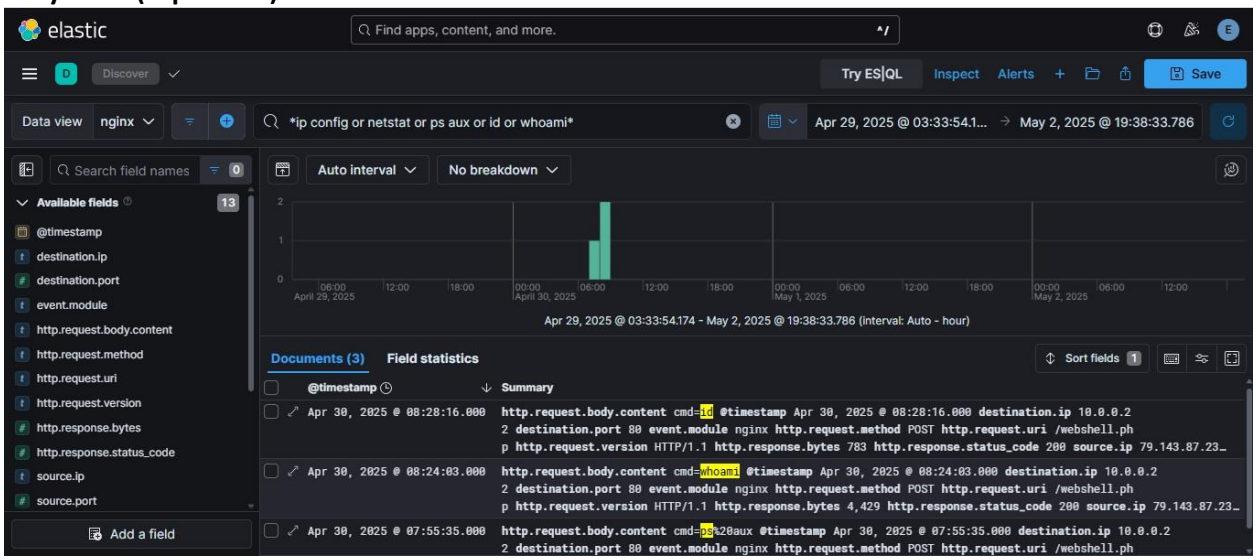
Этап 3

Запрос 1

Что ищем: Ожидаем, что злоумышленник попав на периметр, будет выполнять команды разведки

```
Запрос: *ip config or netstat or ps aux or id or whoami*
```

Результат (скриншот):

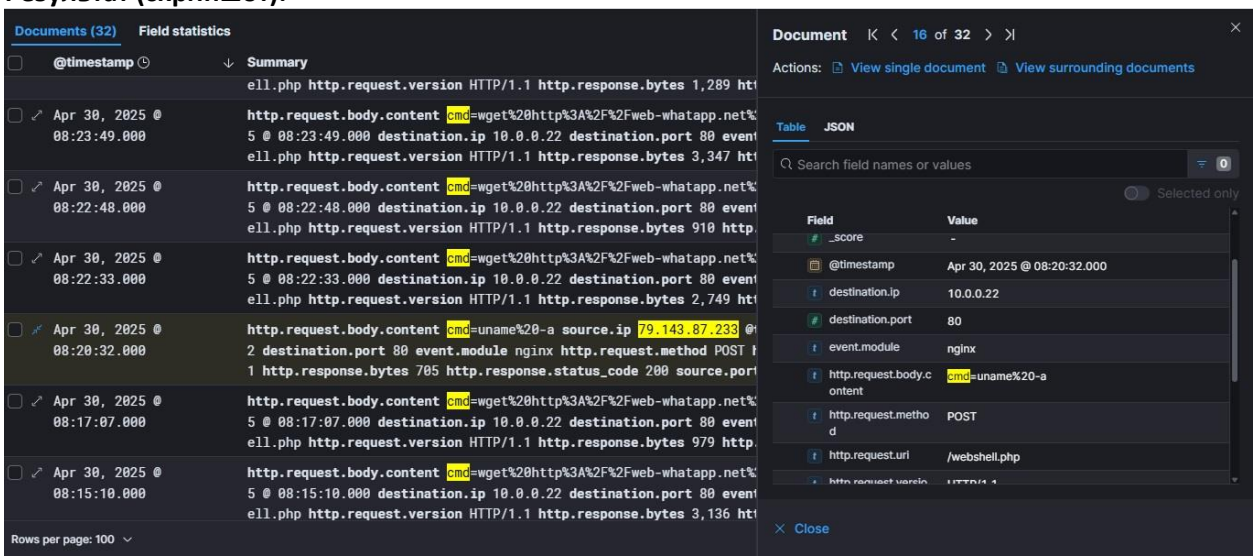


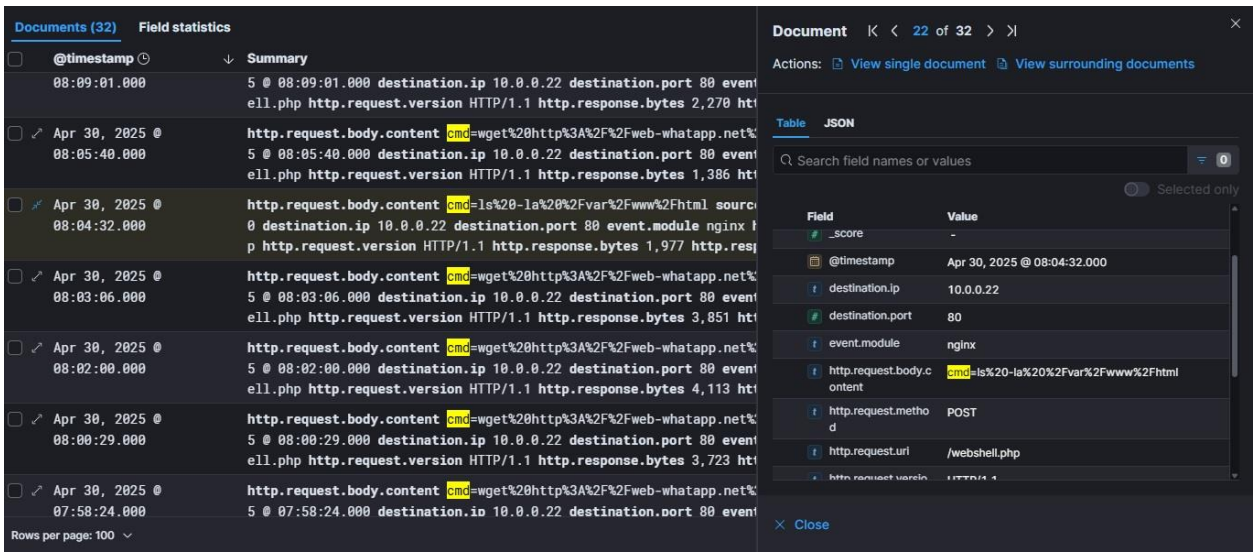
Запрос 2

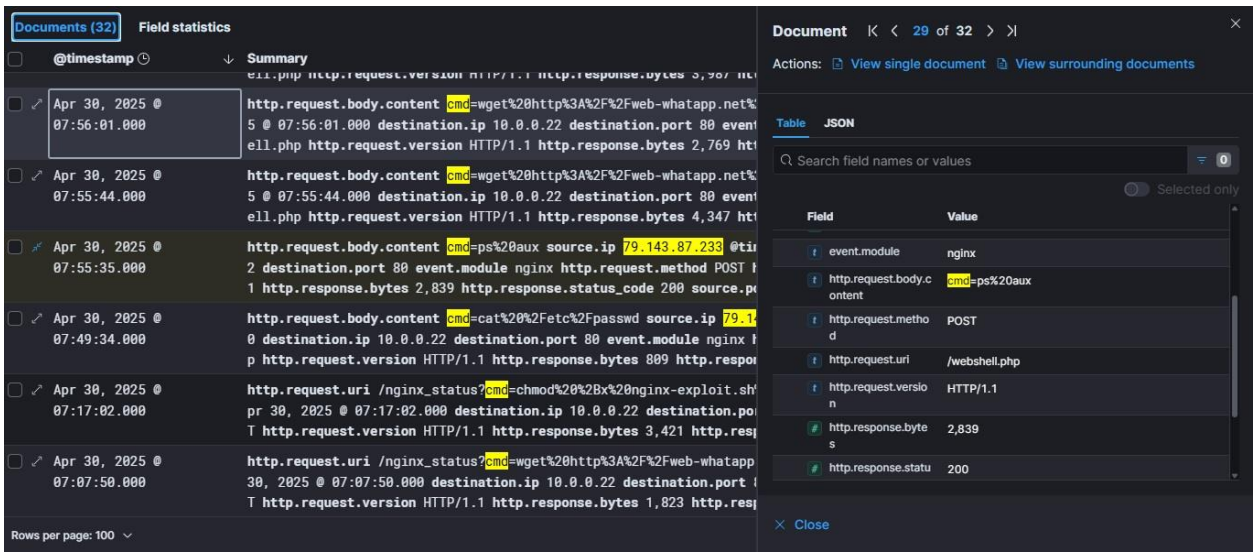
Что ищем: Видим, что на предыдущем этапе команды разведки запускались через webshell, ищем все, что запускалось через webshell

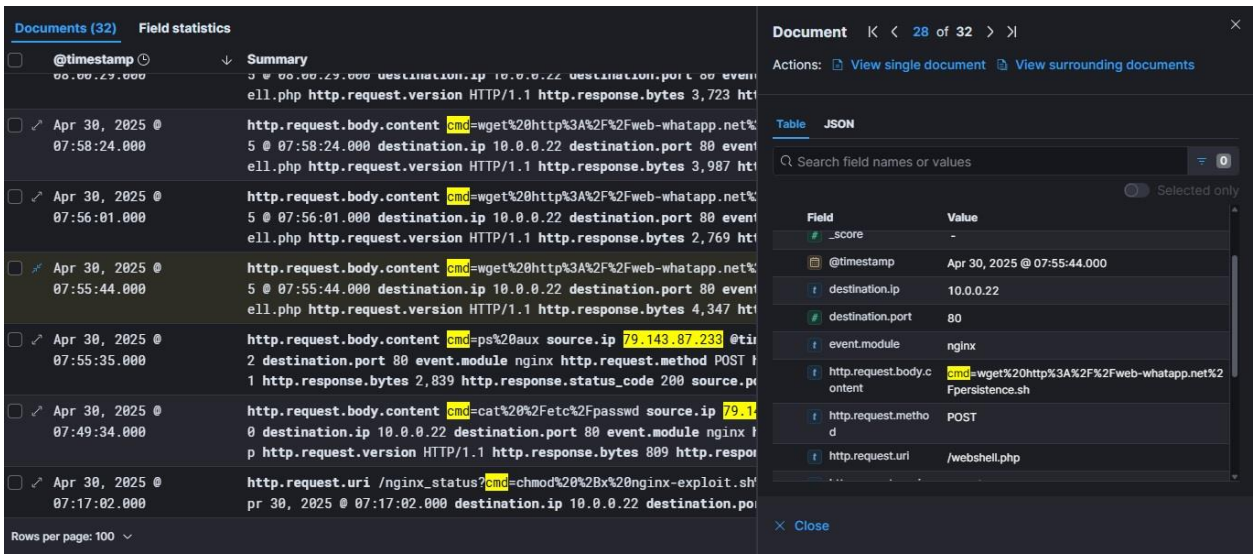
```
Запрос: *webshell*
```

Результат (скриншот):







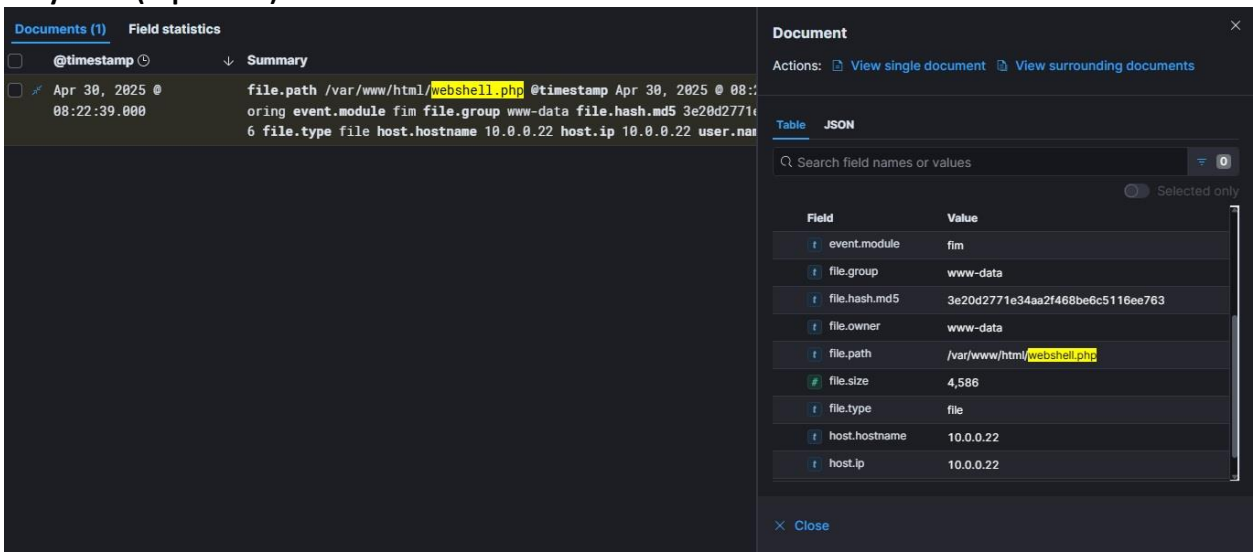


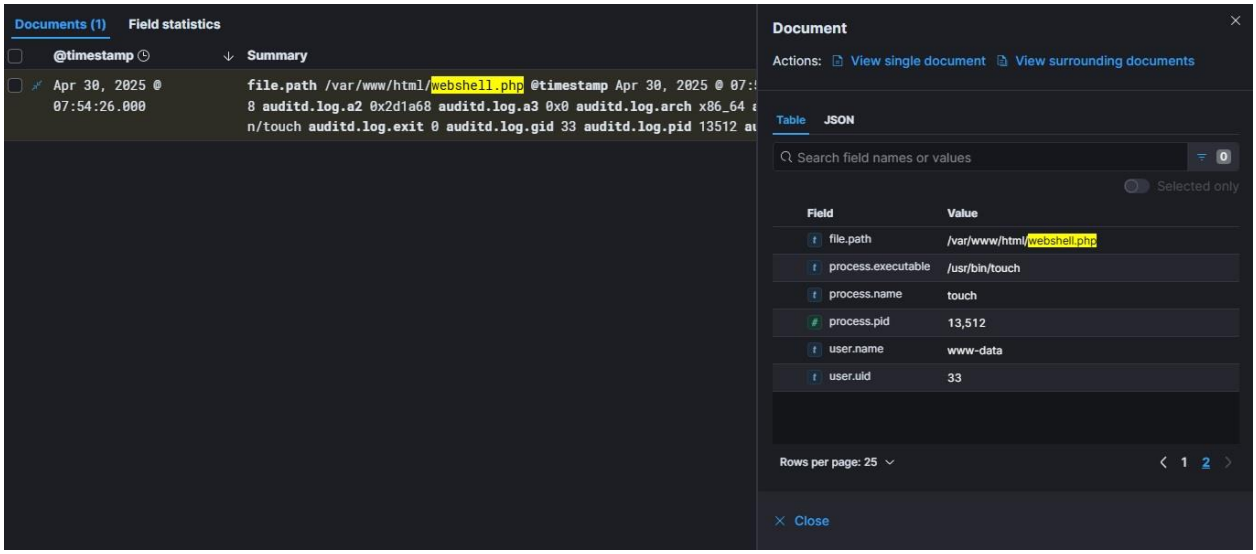
Запрос 3

Что ищем: На предыдущем этапе мы видели что через webshell было загружено предположительно ВПО для закрепления. В дальнейшем пойдем искать эти события, а пока подтверждаем логами индексов FIM и auditd создание webshell

```
Запрос: *webshell*
```

Результат (скриншот):





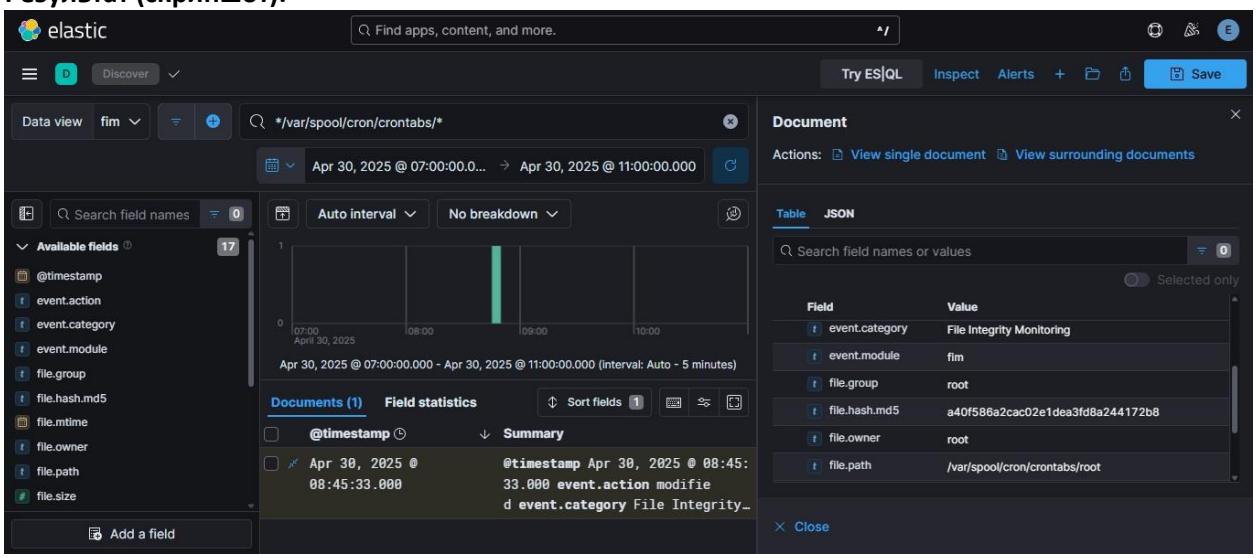
Этап 4

Запрос 1

Что ищем: Поскольку мы не видели прямого запуска persistence.sh ни в одном из индексов, ищем закрепление в crontab в FIM

```
запрос: */var/spool/cron/crontabs/*
```

Результат (скриншот):

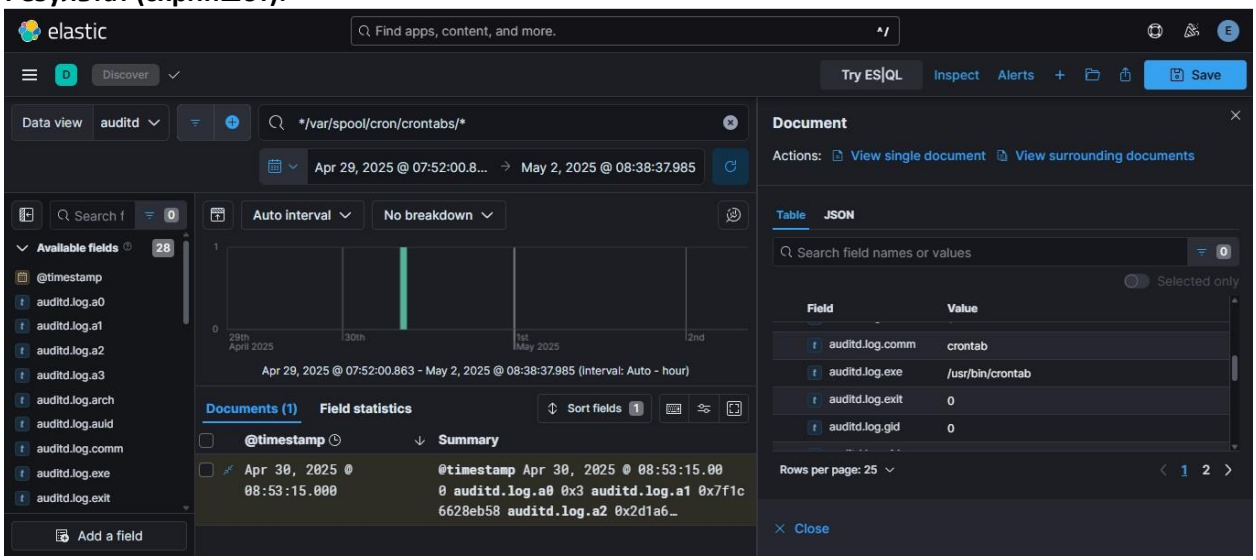


Запрос 2

Что ищем: Ищем подтверждение закрепления еще в индексе auditd:

```
запрос: */var/spool/cron/crontabs/*
```

Результат (скриншот):



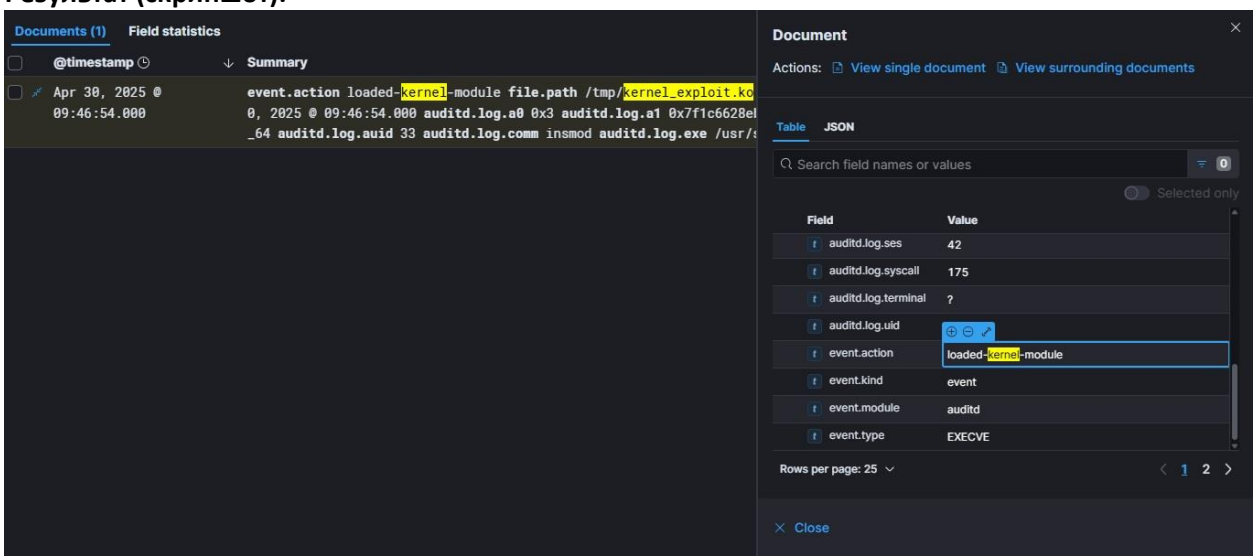
Этап 5

Запрос 1

Что ищем: Ищем возможное повышение привелегий

```
запрос: *kernel*
```

Результат (скриншот):



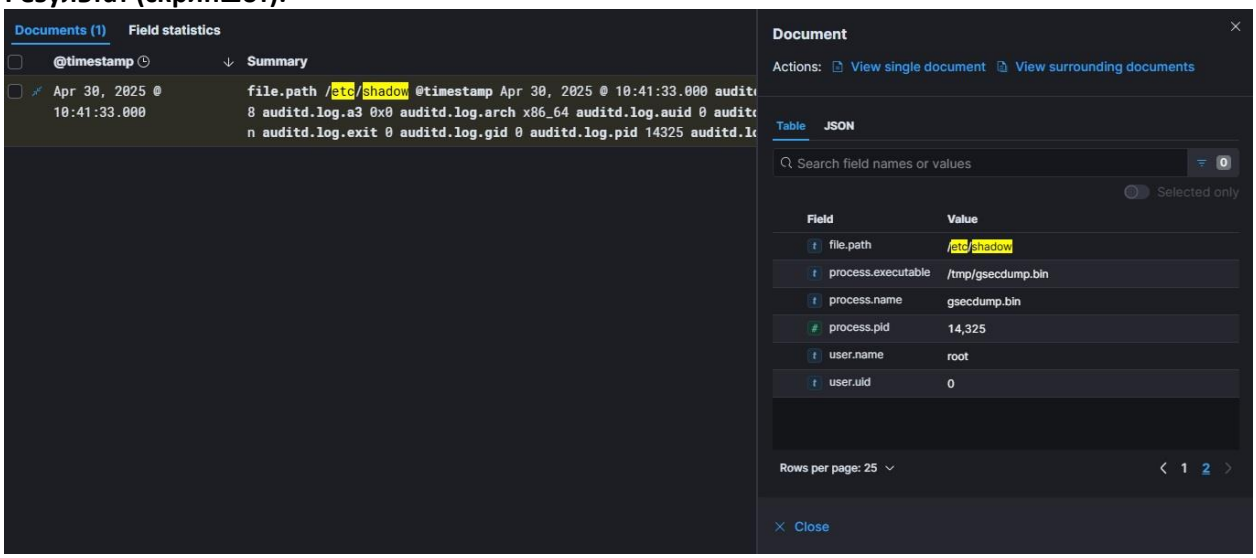
Этап 6

Запрос 1

Что ищем: Следующим шагом будет проверить к каким данным, мог получить доступ злоумышленник. Т.е. например, /etc/shadow, /etc/passwd и т.п

```
запрос: */etc/shadow or /etc/passwd*
```

Результат (скриншот):



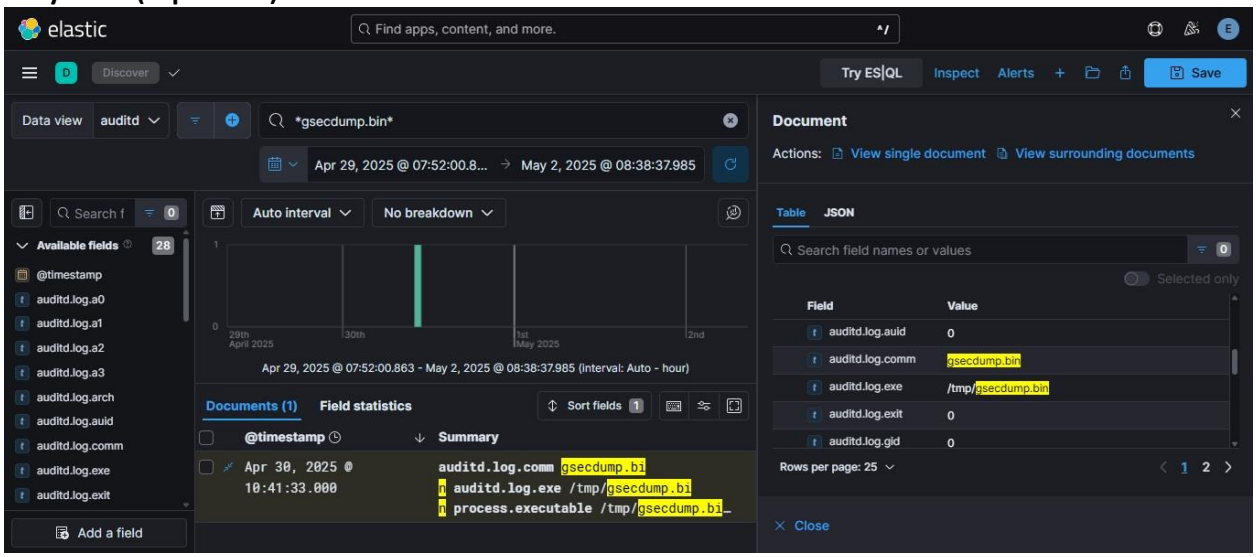
*Находим утилиту /tmp/**gsecdump.bin** – для линукс странно... Ну ок

Запрос 2

Что ищем: убеждаемся что **gsecdump.bin** существует в логах в индексе auditd

```
запрос: *gsecdump.bin*
```

Результат (скриншот):



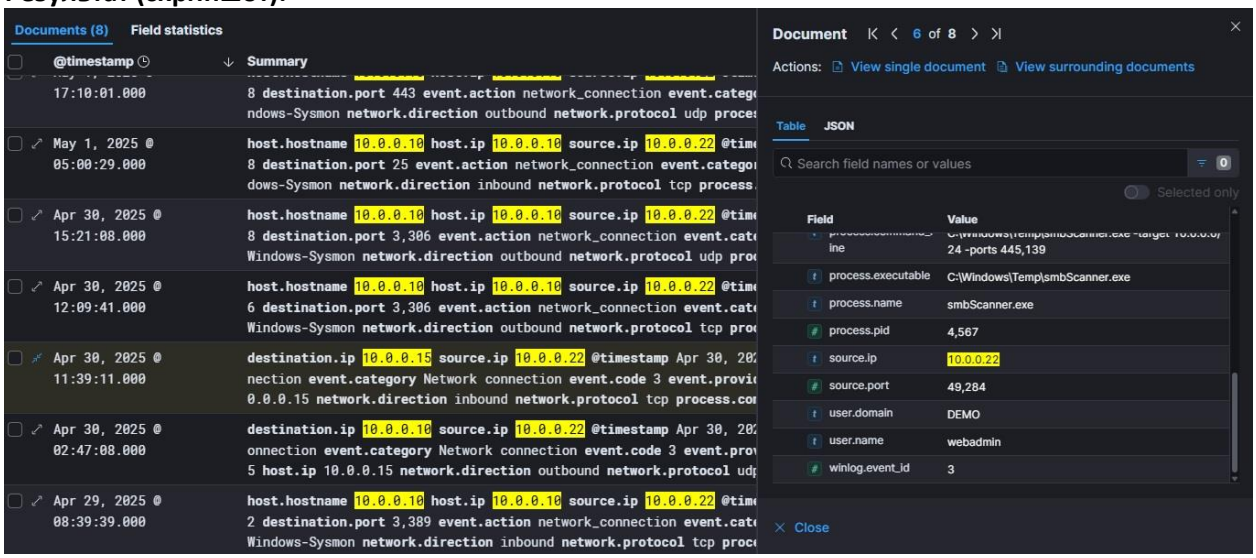
Этап 7

Запрос 1

Что ищем: Далее после того, как злоумышленник получил данные от учетки 10.0.0.22, мы предполагаем, что он мог совершить боковое перемещение или производить разведку на один из функционирующих в домене хостов - контроллер домена (10.0.0.10) или файловый сервер (10.0.0.15)

```
запрос: source.ip: 10.0.0.22 and event.code: 3 and (destination.ip: 10.0.0.15 or 10.0.0.10)
```

Результат (скриншот):

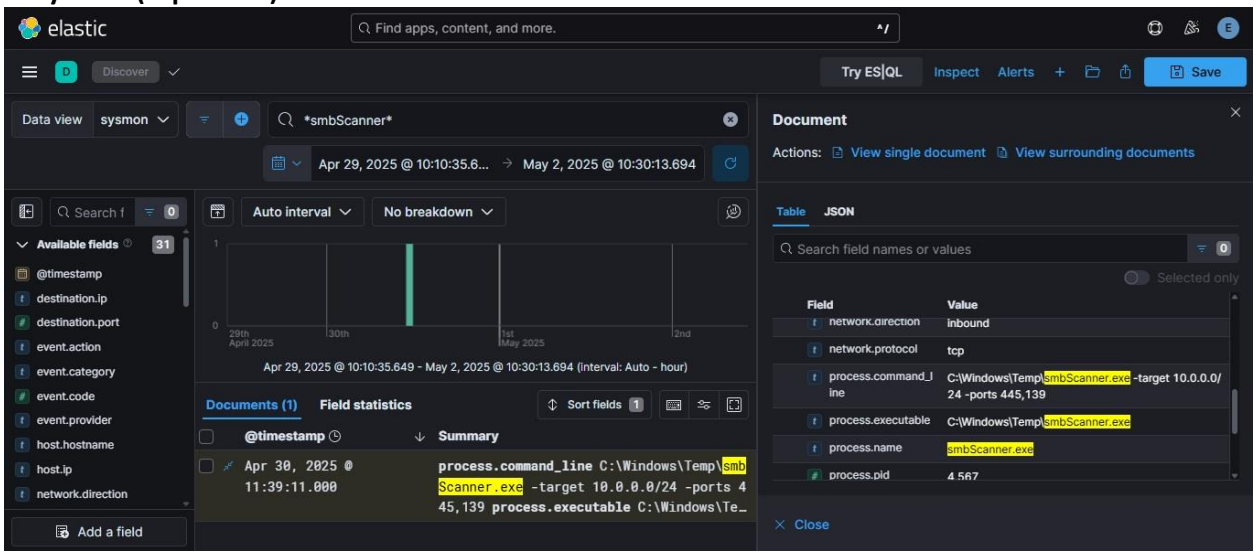


Запрос 2

Что ищем: Находим и подтверждаем наличие сканера, т.е. злоумышленник перед латеральным перемещением, производил разведку. Убеждаемся что сканнер присутствует. Далее смотрим, что он делает – а именно сканирует сеть 10.0.0.0.24 и порты 445 и 139

```
запрос: *smbScanner*
```

Результат (скриншот):



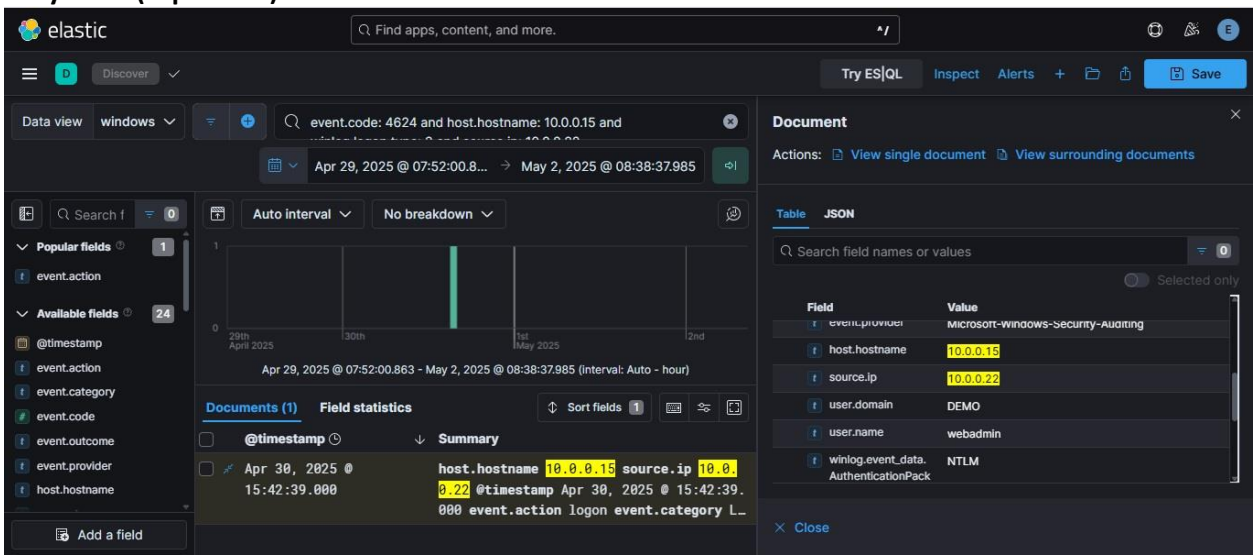
Этап 8

Запрос 1

Что ищем: Ищем латеральное перемещение злоумышленника на файловый сервер - 10.0.0.15

```
запрос: event.code: 4624 and host.hostname: 10.0.0.15 and winlog.logon.type: 3 and source.ip: 10.0.0.22
```

Результат (скриншот):



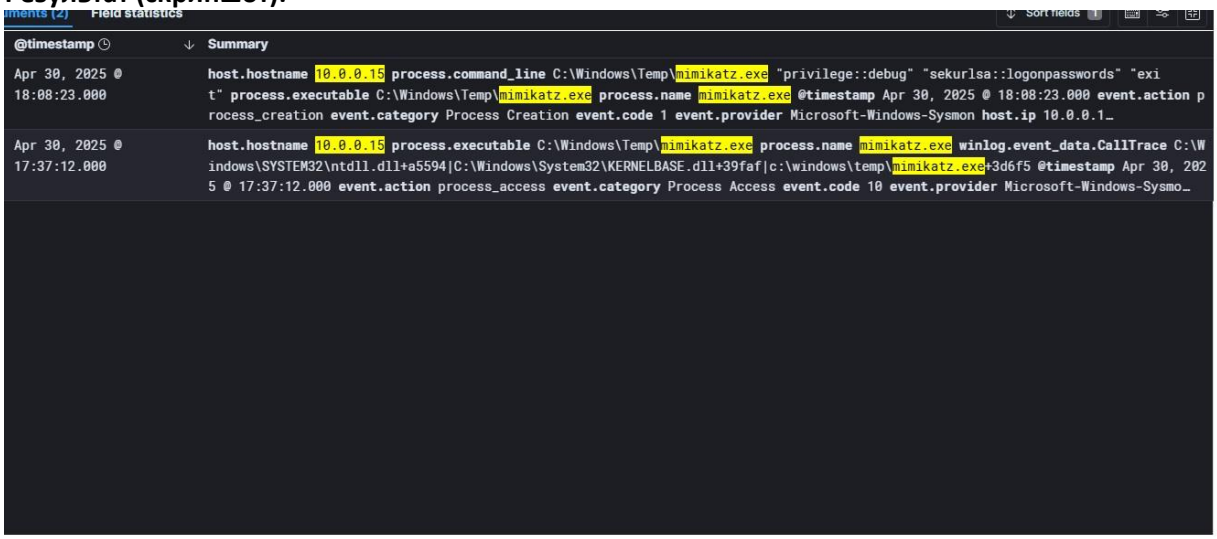
Этап 9

Запрос 1

Что ищем: После получения злоумышленником доступа на файловый сервер - 10.0.0.15. Мы ищем возможные попытки закрепления на сервере или попытки кражи учетных данных с помощью хакерских утилит, таких как, например mimikatz

```
запрос:  host.hostname: 10.0.0.15 AND *mimikatz*
```

Результат (скриншот):

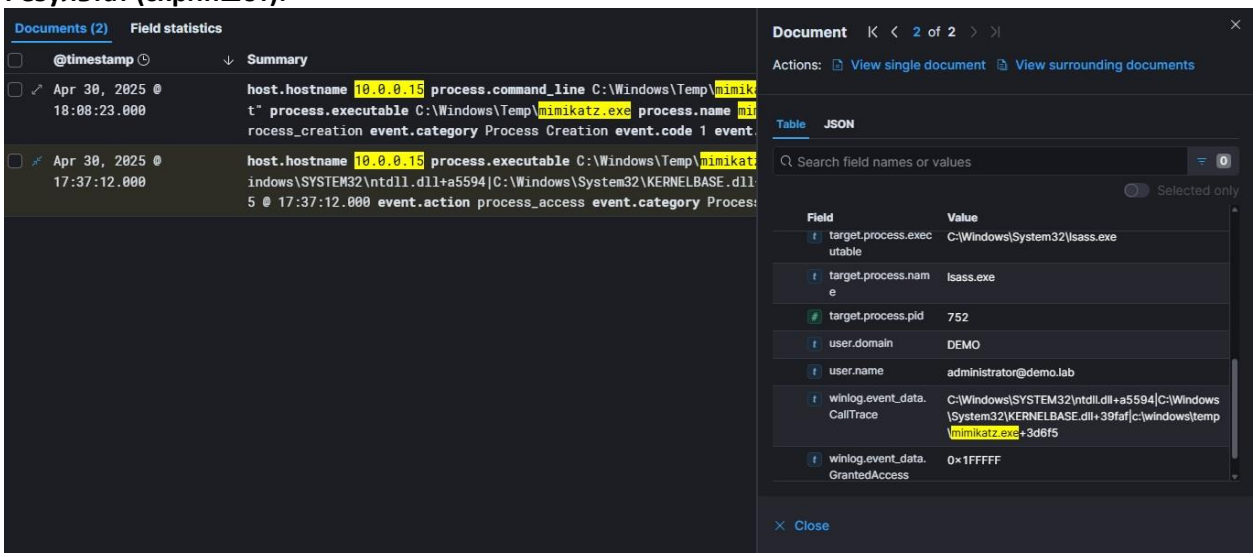


Запрос 2

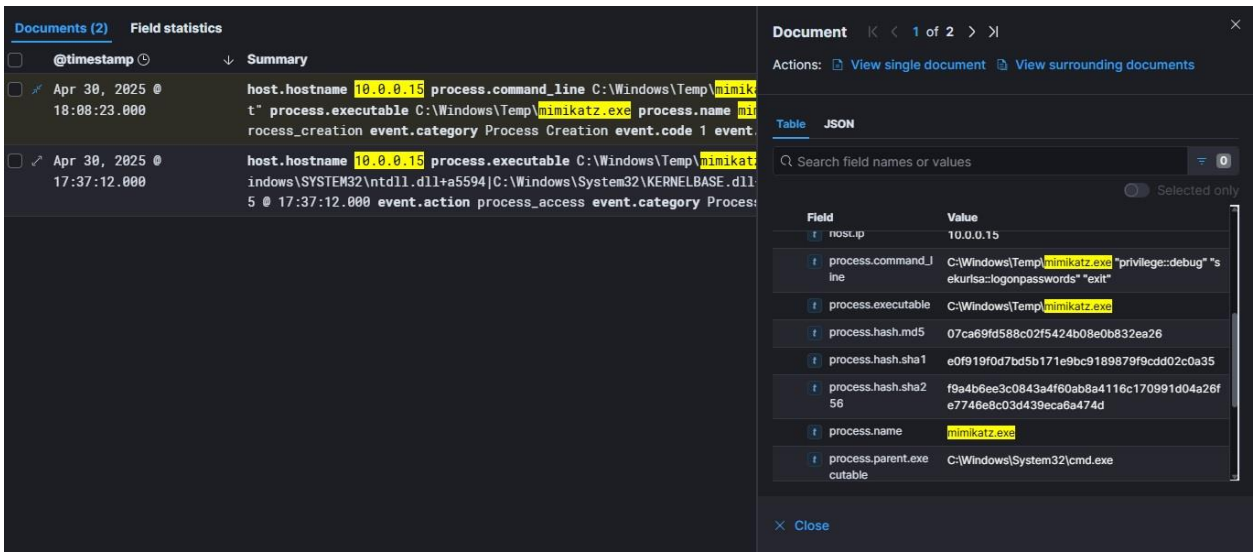
Что ищем: Доступ к процессу lsass.exe это ключевой признак дампа.

запрос: host.hostname: 10.0.0.15 AND *mimikatz*

Результат (скриншот):



Хэши mimikatz:



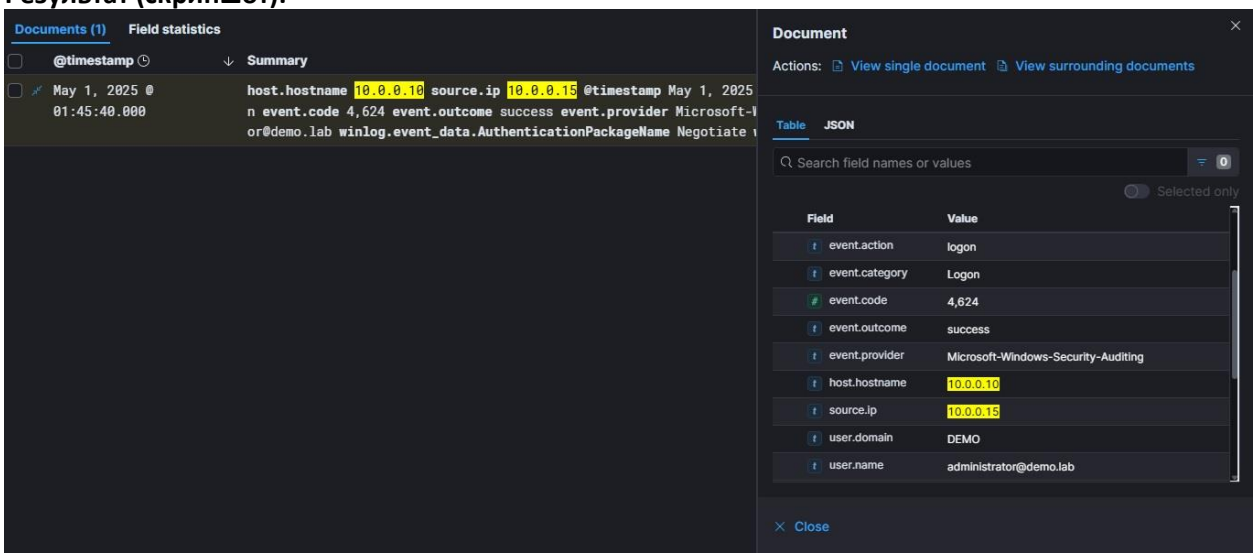
Этап 10

Запрос 1

Что ищем: В предыдущем этапе расследование мы видели, как злоумышленник сделал дамп памяти с помощью утилиты mimikatz на файловом сервере. Теперь необходимо проверить контроллер домена на наличие тех же самых утилит. Вполне вероятно, что злоумышленник получив данные из дампа памяти на файловом сервере, сможет получить доступ на контроллер домена

```
запрос: event.code: 4624 and host.hostname: 10.0.0.10 and winlog.logon.type: 10 and source.ip: 10.0.0.15
```

Результат (скриншот):



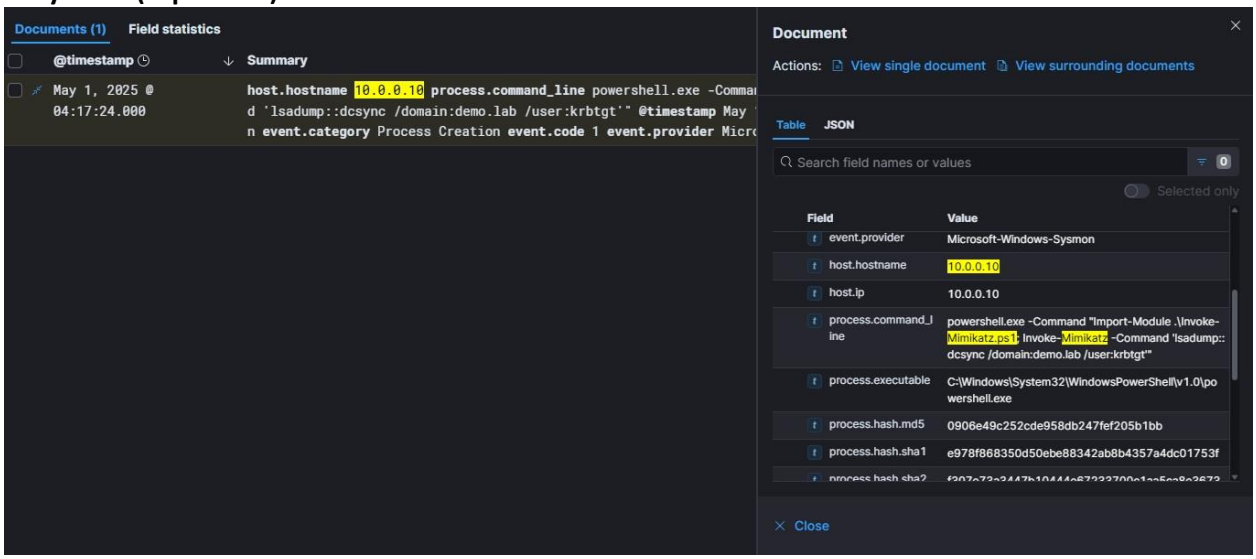
Этап 11

Запрос 1

Что ищем: Ищем запуск вредоносных утилит, таких как mimikatz на контроллере домена

```
запрос: host.hostname: 10.0.0.10 AND *mimikatz*
```

Результат (скриншот):

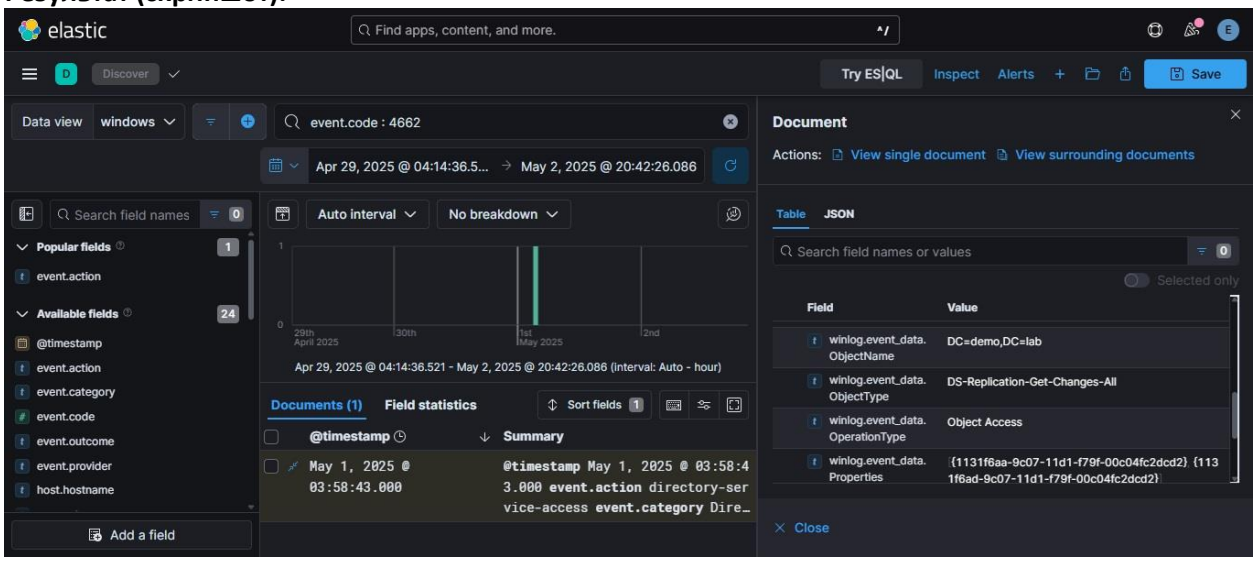


Запрос 2

Что ищем: Ищем также подтверждение в логах индекса Windows

```
запрос: event.code: 4662
```

Результат (скриншот):



Этап 12

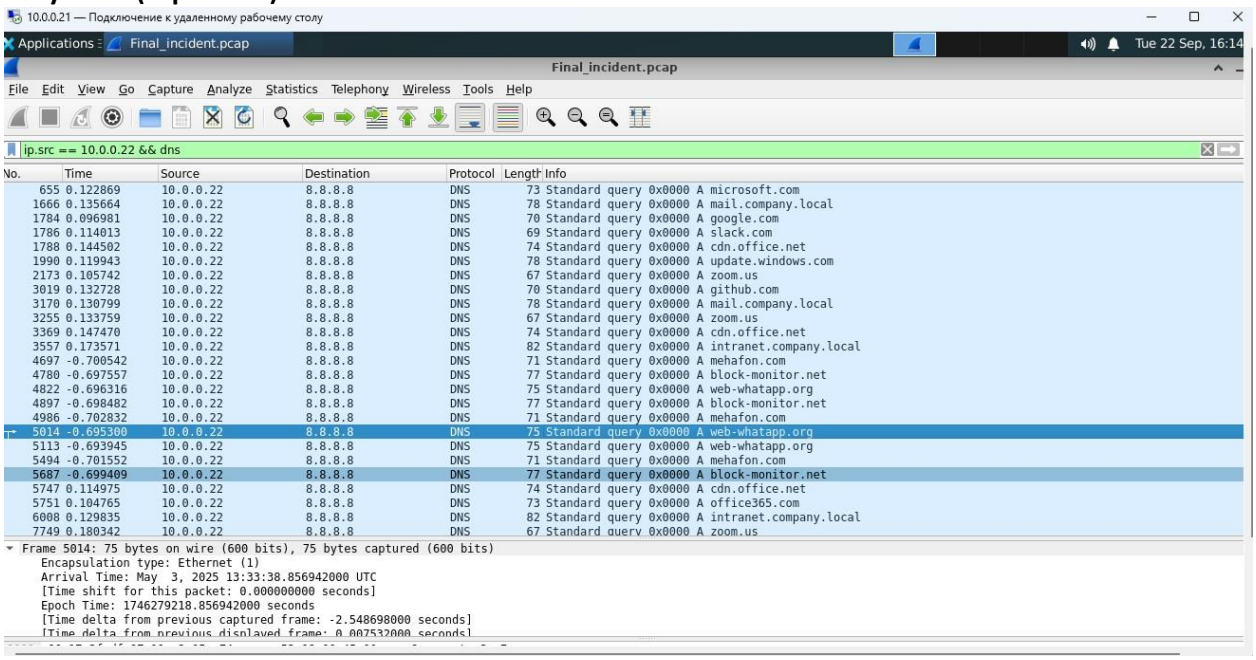
Запрос 1

Что ищем: После компрометации всех ключевых и критичных для компании систем внутри домена. Т.к. был получен секрет из krbtgt, можно сделать вывод, что злоумышленник будет пытаться похитить все те данные, которые имеются в активах всей скомпрометированной доменной зоны.

*Запрос производим из файла PCAP. Файл final_incident.pcap с сетевой активностью на рабочем столе хоста 10.0.0.21

```
запрос: ip.src == 10.0.0.22 && dns
```

Результат (скриншот):

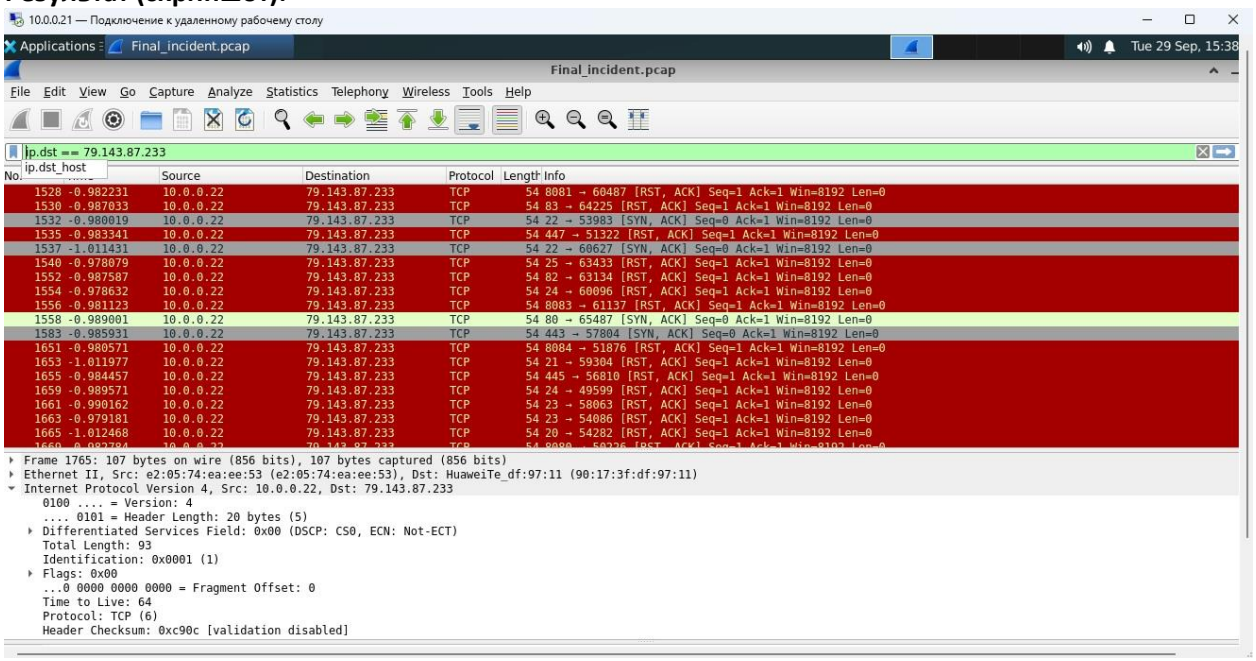


Запрос 2

Что ищем: Мы знаем подозрительные ip- адреса, которые фигурировали в сканировании и других событиях, поэтому далее стоит поискать информацию по ним

```
запрос: ip.dst == 79.143.87.233
```

Результат (скриншот):



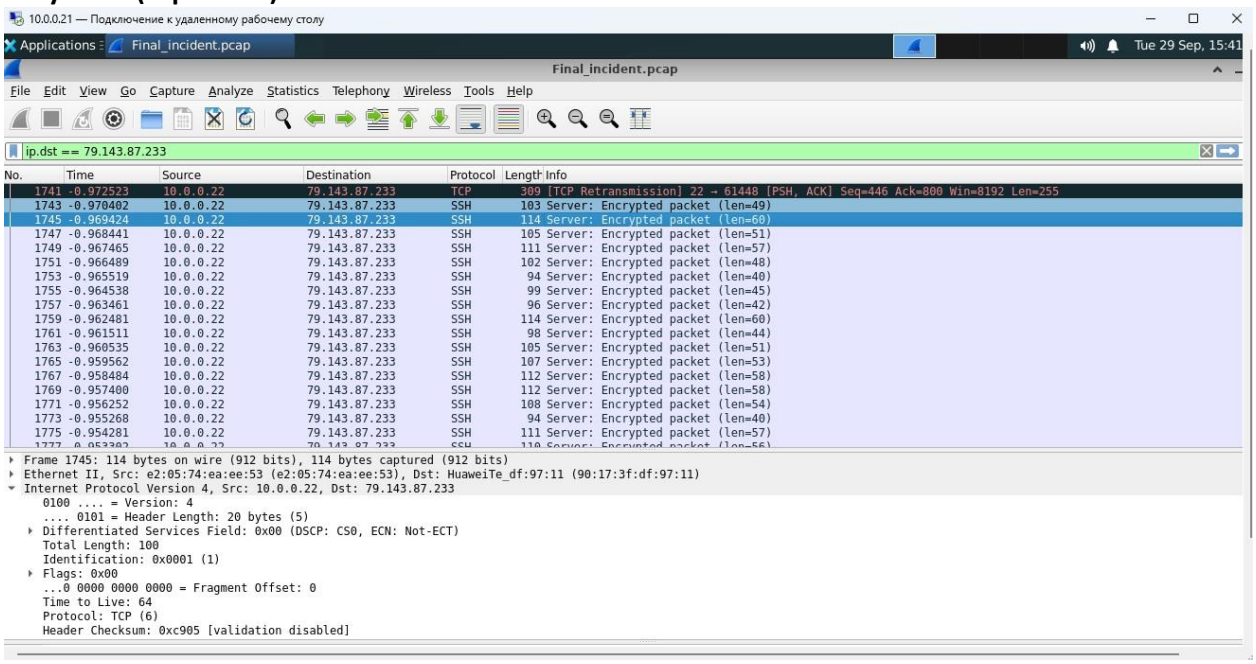
*Здесь подтверждаем, что было сканирование портов

Запрос 3

Что ищем: Ищем подтверждение подключения с веб-сервера

```
запрос: ip.dst == 79.143.87.233
```

Результат (скриншот):

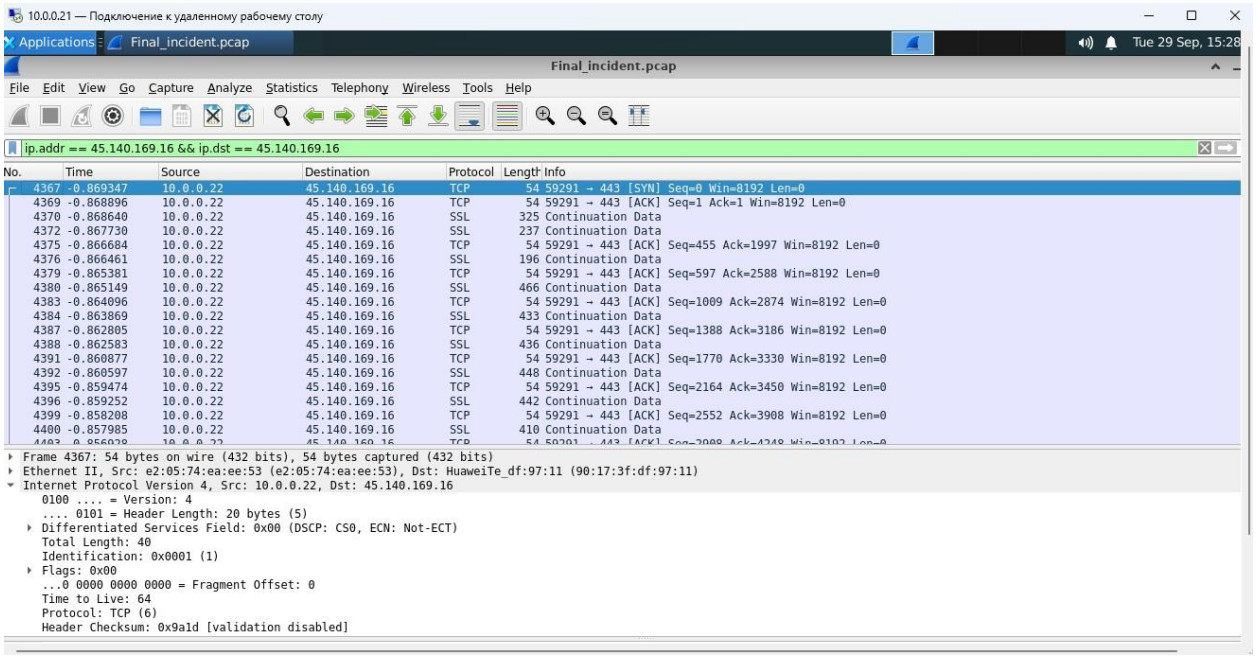


Запрос 4

Что ищем: Пытаемся из подозрительных ip-адресов найти эксфильтрацию данных

```
запрос:  ip.addr == 45.140.169.16 && ip.dst == 45.140.169.16
```

Результат (скриншот):

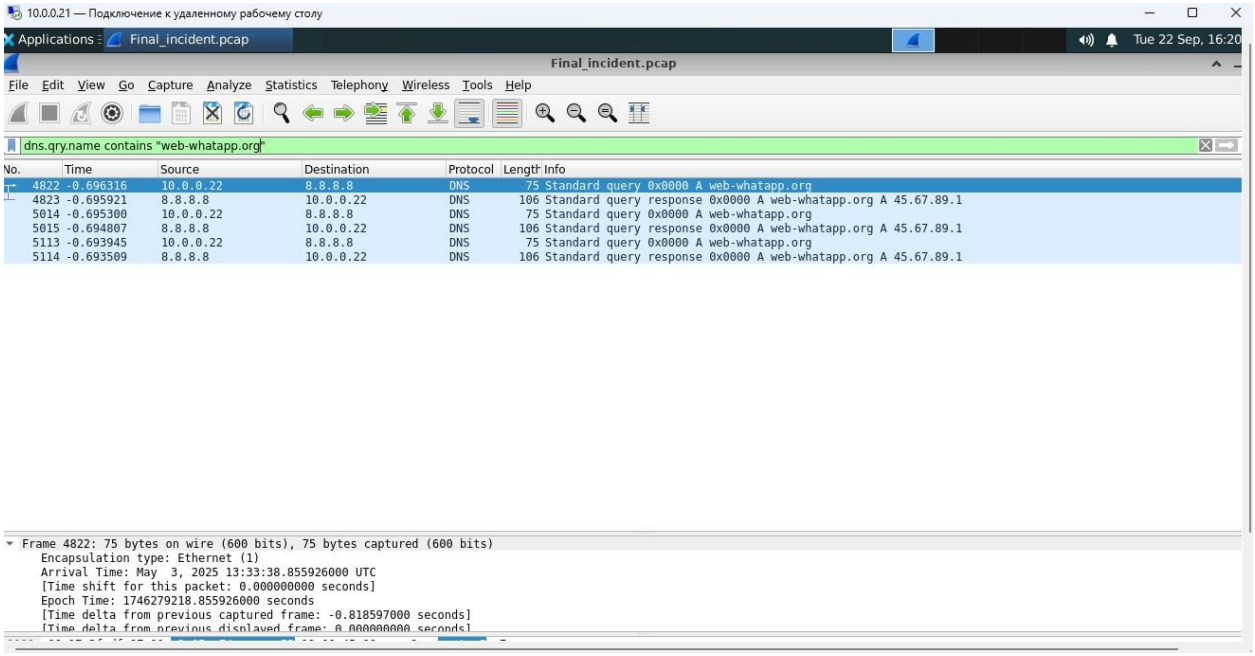


Запрос 5

Что ищем: DNS-резолв домена web-whatapp.org узнать IP C2.

```
запрос: dns.qry.name contains "web-whatapp.org"
```

Результат (скриншот):

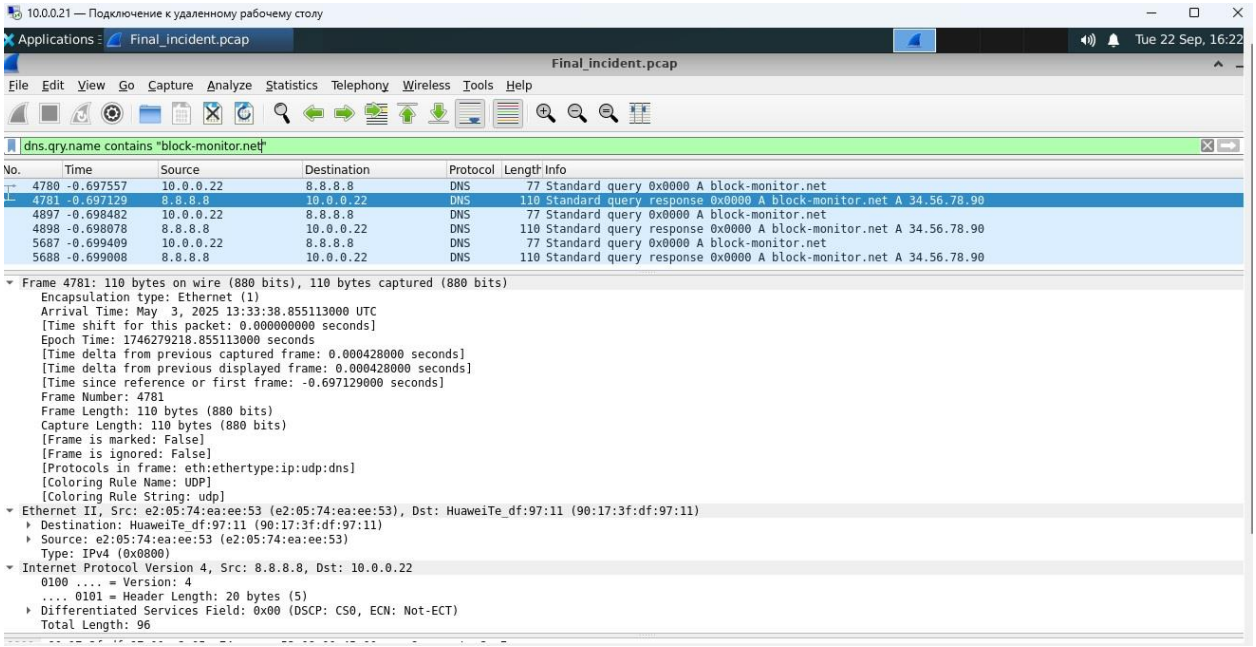


Запрос 6

Что ищем: DNS-резолв домена block-monitor.net — узнать второй IP C2

```
запрос: dns.qry.name contains "block-monitor.net"
```

Результат (скриншот):

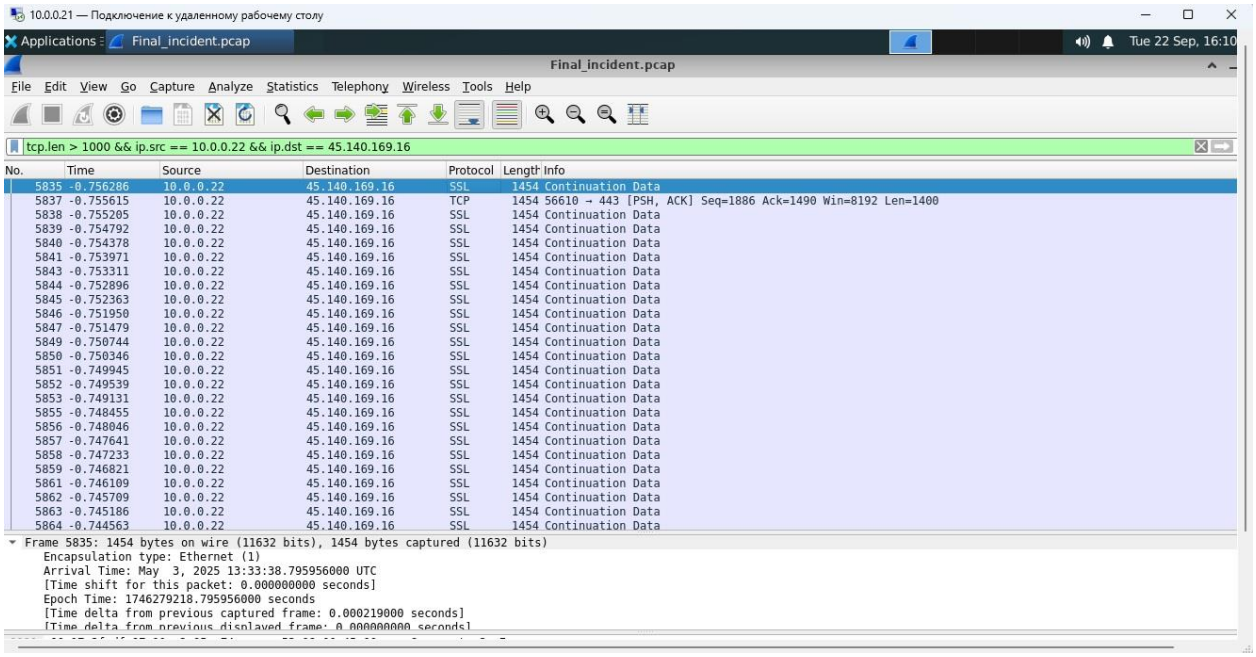


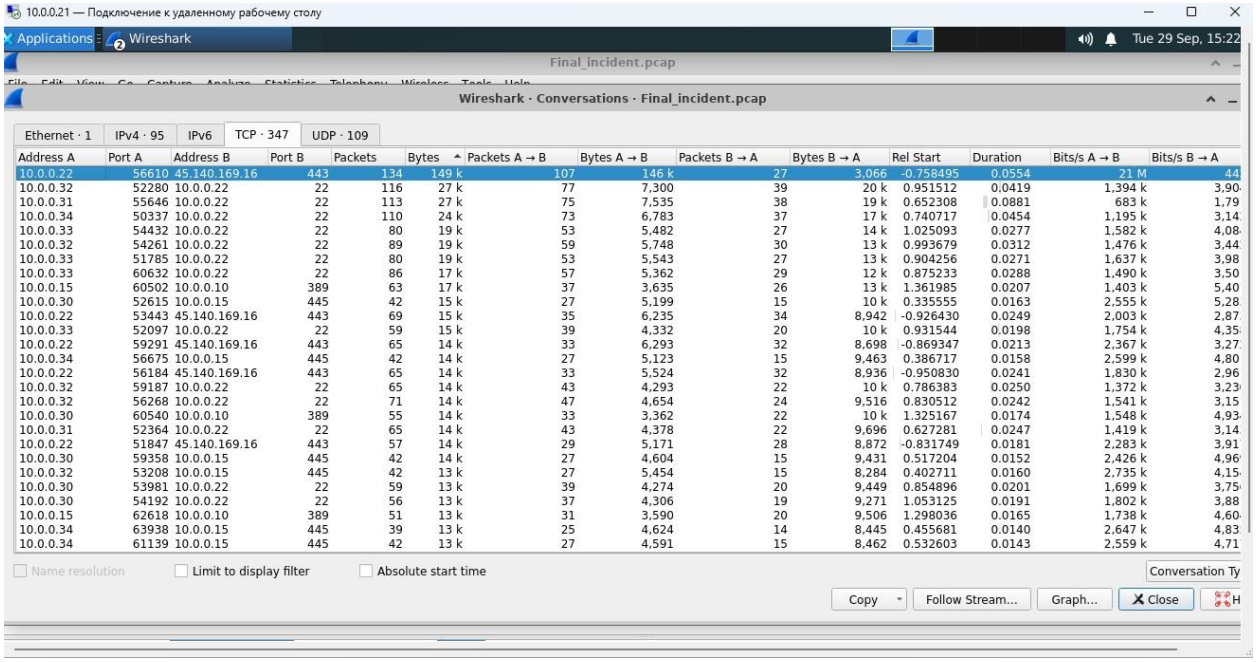
Запрос 7

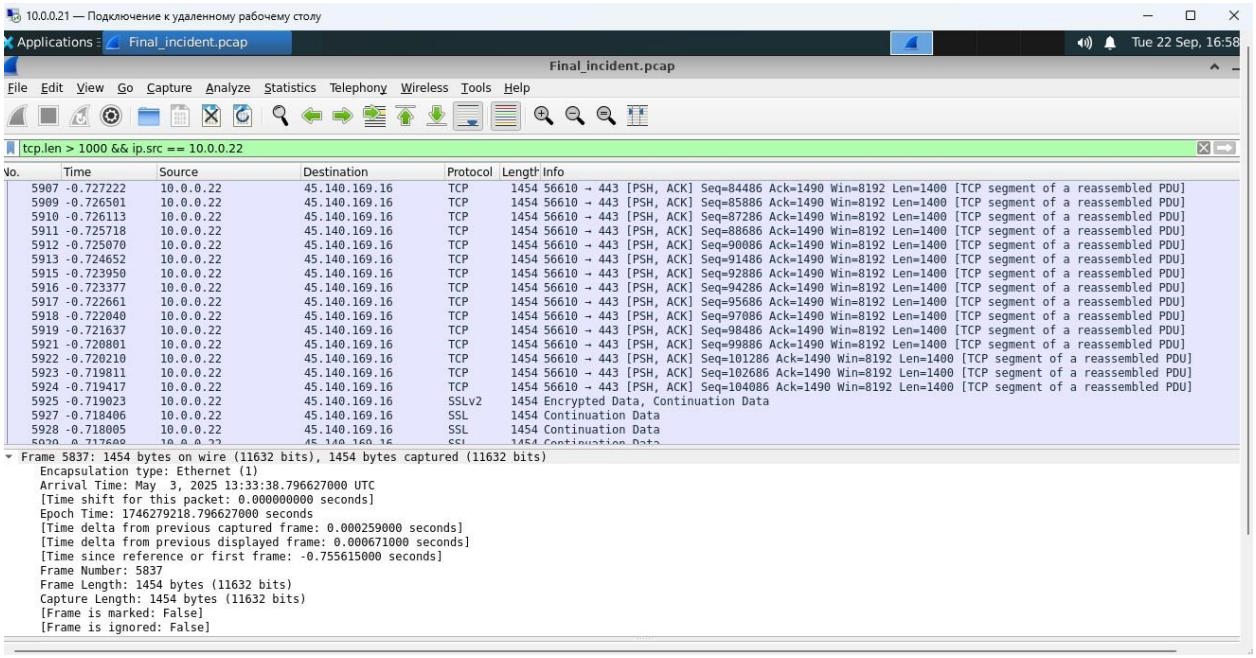
Что ищем: Подтвердить TLS-эксфильтрацию — большие пакеты от веб-сервера к приёмнику

```
запрос: tcp.len > 1000 && ip.src == 10.0.0.22 && ip.dst == 45.140.169.16
```

Результат (скриншот):


10.0.0.21 — Подключение к удаленному рабочему столу
Applications
Final_incident.pcap
Tue 22 Sep, 16:10
Final_incident.pcap
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
tcp.len > 1000 && ip.src == 10.0.0.22 && ip.dst == 45.140.169.16
No. Time Source Destination Protocol Length Info
5835 -0.756286 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5837 -0.755615 10.0.0.22 45.140.169.16 TCP 1454 56610 → 443 [PSH, ACK] Seq=1886 Ack=1490 Win=8192 Len=1400
5838 -0.755205 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5839 -0.754792 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5840 -0.754378 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5841 -0.753971 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5843 -0.753311 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5844 -0.752896 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5845 -0.752363 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5846 -0.751950 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5847 -0.751479 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5849 -0.750744 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5850 -0.750346 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5851 -0.749945 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5852 -0.749539 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5853 -0.749131 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5855 -0.748455 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5856 -0.748046 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5857 -0.747641 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5858 -0.747233 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5859 -0.746821 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5861 -0.746109 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5862 -0.745709 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5863 -0.745186 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5864 -0.744563 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
Frame 5835: 1454 bytes on wire (11632 bits), 1454 bytes captured (11632 bits)
Encapsulation type: Ethernet (1)
Arrival Time: May 3, 2025 13:33:38.795956000 UTC
[Time shift for this packet: 0.000000000 seconds]
Epoch Time: 1746279218.795956000 seconds
[Time delta from previous captured frame: 0.000219000 seconds]


10.0.0.21 — Подключение к удаленному рабочему столу
Applications
Wireshark
Tue 29 Sep, 15:22
Final_incident.pcap
Wireshark · Conversations · Final_incident.pcap
Ethernet · 1 IPv4 · 95 IPv6 TCP · 347 UDP · 109
Address A Port A Address B Port B Packets Bytes Packets A → B Bytes A → B Packets B → A Bytes B → A Rel Start Duration Bits/s A → B Bits/s B → A
10.0.0.22 56610 45.140.169.16 443 134 149 k 107 146 k 27 3,066 -0.758495 0.0554 21 M 44
10.0.0.32 52280 10.0.0.22 22 116 27 k 77 7,300 39 20 k 0.951512 0.0419 1,394 k 3,90
10.0.0.31 55646 10.0.0.22 22 113 27 k 75 7,535 38 19 k 0.652308 0.0881 683 k 1,79
10.0.0.34 50337 10.0.0.22 22 110 24 k 73 6,783 37 17 k 0.740717 0.0454 1,195 k 3,14
10.0.0.33 54432 10.0.0.22 22 80 19 k 53 5,482 27 14 k 1.025093 0.0277 1,582 k 4,08
10.0.0.32 54261 10.0.0.22 22 89 19 k 59 5,748 30 13 k 0.993679 0.0312 1,476 k 3,44
10.0.0.33 51785 10.0.0.22 22 80 19 k 53 5,543 27 13 k 0.904256 0.0271 1,637 k 3,98
10.0.0.33 60632 10.0.0.22 22 86 17 k 57 5,362 29 12 k 0.875233 0.0288 1,490 k 3,50
10.0.0.15 60502 10.0.0.10 389 63 17 k 37 3,635 26 13 k 1.361985 0.0207 1,403 k 5,40
10.0.0.30 52615 10.0.0.15 445 42 15 k 27 5,199 15 10 k 0.335555 0.0163 2,555 k 5,28
10.0.0.22 53443 45.140.169.16 443 69 15 k 35 6,235 34 8,942 -0.926430 0.0249 2,003 k 2,87
10.0.0.33 52097 10.0.0.22 22 59 15 k 39 4,332 20 10 k 0.931544 0.0198 1,754 k 4,35
10.0.0.22 59291 45.140.169.16 443 65 14 k 33 6,293 32 8,698 -0.869347 0.0213 2,367 k 3,27
10.0.0.34 56675 10.0.0.15 445 42 14 k 27 5,123 15 9,463 0.386717 0.0158 2,599 k 4,80
10.0.0.22 56184 45.140.169.16 443 65 14 k 33 5,524 32 8,936 -0.950830 0.0241 1,830 k 2,96
10.0.0.32 59187 10.0.0.22 22 65 14 k 43 4,293 22 10 k 0.786383 0.0250 1,372 k 3,23
10.0.0.32 56268 10.0.0.22 22 71 14 k 47 4,654 24 9,516 0.830512 0.0242 1,541 k 3,15
10.0.0.30 60540 10.0.0.10 389 55 14 k 33 3,362 22 10 k 1.325167 0.0174 1,548 k 4,93
10.0.0.31 52364 10.0.0.22 22 65 14 k 43 4,378 22 9,696 0.627281 0.0247 1,419 k 3,14
10.0.0.22 51847 45.140.169.16 443 57 14 k 29 5,171 28 8,872 -0.831749 0.0181 2,283 k 3,91
10.0.0.30 59358 10.0.0.15 445 42 14 k 27 4,604 15 9,431 0.517204 0.0152 2,426 k 4,96
10.0.0.32 53208 10.0.0.15 445 42 13 k 27 5,454 15 8,284 0.402711 0.0160 2,735 k 4,15
10.0.0.30 53981 10.0.0.22 22 59 13 k 39 4,274 20 9,449 0.854896 0.0201 1,699 k 3,75
10.0.0.30 54192 10.0.0.22 22 56 13 k 37 4,306 19 9,271 1.053125 0.0191 1,802 k 3,88
10.0.0.15 62618 10.0.0.10 389 51 13 k 31 3,590 20 9,506 1.298036 0.0165 1,738 k 4,60
10.0.0.34 63938 10.0.0.15 445 39 13 k 25 4,624 14 8,445 0.455681 0.0140 2,647 k 4,83
10.0.0.34 61139 10.0.0.15 445 42 13 k 27 4,591 15 8,462 0.532603 0.0143 2,559 k 4,71
Name resolution
Limit to display filter
Absolute start time
Conversation Ty
Copy
Follow Stream...
Graph...
Close

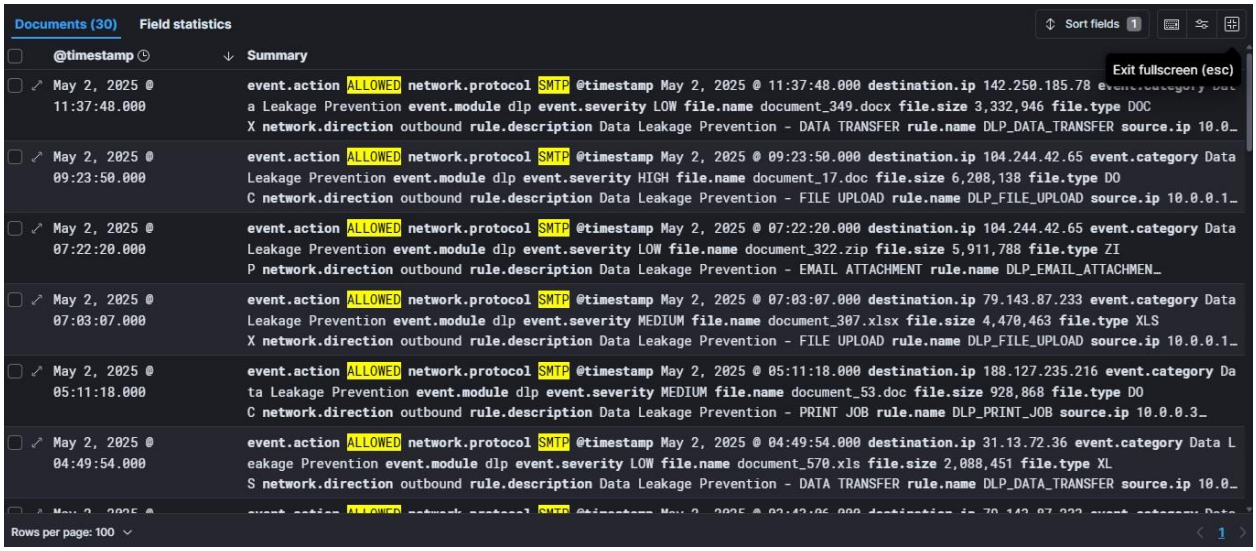


Запрос 8

Что ищем: Эксфильтрация через SMTP. Находим подтверждение данным из wireshark

```
запрос: network.protocol: SMTP AND event.action: ALLOWED
```

Результат (скриншот):

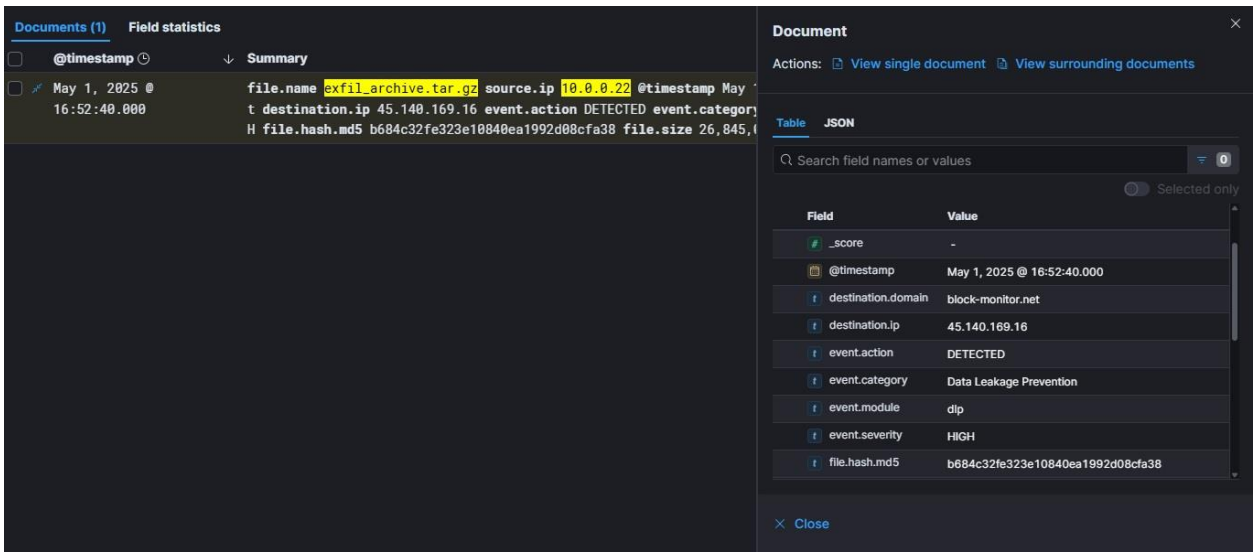


Запрос 9

Что ищем: Крупная эксфильтрация с веб-сервера

```
запрос: source.ip: 10.0.0.22 AND file.name: *exfil_archive*
```

Результат (скриншот):



Этап 13

Запрос 1

Что ищем: Факт удаления или очистки журналов аудита или попытку атакующего скрыть следы своего присутствия

```
запрос: event.code: 1102
```

Результат (скриншот):

